



CIEM BEST PRACTICES CHEAT SHEET

Cut the access your identities never use

The do's and don'ts for six cloud and Kubernetes identity practices, with the AccuKnox screen that checks each one.

Identities hold far more access than they **use**

Every cloud account collects users, roles and keys faster than a team reviews them. The unused access stays live, and an attacker who takes one identity gets all of it.

2%

of 51,000 granted permissions were used. Microsoft rated 50% of those permissions high risk.

Microsoft, 2024 State of Multicloud Security Risk Report. microsoft.com

83%

of the cloud compromises Google Cloud studied rested on an identity compromise.

Google Cloud, Cloud Threat Horizons Report H1 2026. cloud.google.com

59%

of AWS IAM users hold an active access key older than one year. Over half of those users left the key unused for 90 days.

Datadog, State of Cloud Security, October 2025. datadoghq.com

Access grows by default and **shrinks by hand**



Machines outnumber people

Microsoft counts one human identity for every 10 workload identities. Each pipeline, function and service account gets a role, and few of those roles have a named owner.



Old identities stay active

A role built for a proof of concept keeps its policies after the project ends. Microsoft reported an average of 80% of workload identities inactive in 2023. An inactive identity keeps every permission it holds.



Groups hide the real grant

A user inherits every policy from every group it joins. A review of the policies attached to the user alone misses the rest, and a policy name says nothing about its statements.



Kubernetes has its own identities

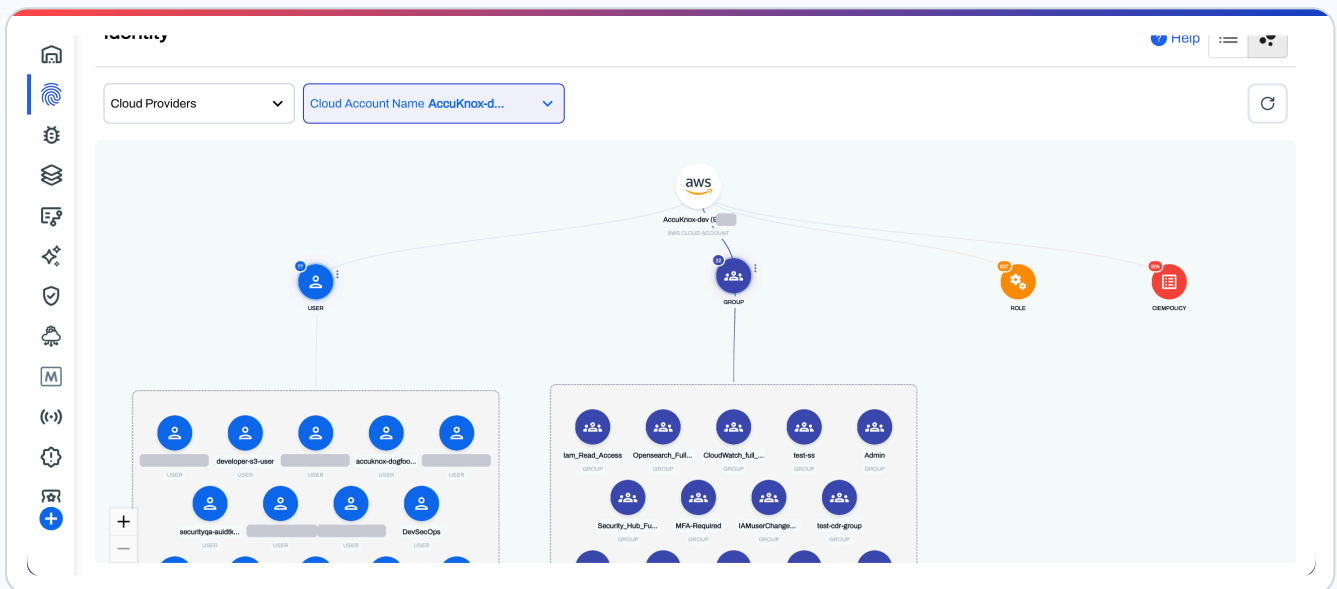
Service accounts, roles and role bindings live inside the cluster. A cloud IAM review never reads them, so a ClusterRole that grants secrets access goes unseen.

Sources: Microsoft, 2024 State of Multicloud Security Risk Report, microsoft.com. Microsoft Entra blog, 2023 State of Cloud Permissions Risks report, techcommunity.microsoft.com.

Start here

Six practices shrink standing access

Start with the inventory, then remove what nobody uses, then read what is left. Kubernetes RBAC gets the same treatment as cloud IAM.



CIEM organization graph of a demo AWS account. help.accuknox.com/getting-started/ciem-overview

- | | | | | | |
|----|--|----|----|---|----|
| 01 | Inventory every identity
Human and machine, in four clouds | 05 | 04 | Read the policy document
The name is not the grant | 08 |
| 02 | Retire dormant identities
Start with the longest idle | 06 | 05 | Trace inherited access
Follow identity to group to policy | 09 |
| 03 | Fix by risk class first
Privilege escalation leads the queue | 07 | 06 | Cover Kubernetes RBAC
Service accounts and role bindings | 10 |

AccuKnox CIEM is in beta and supports standalone AWS, GCP, Azure and OCI accounts. Organization accounts are not supported yet. KIEM is generally available.

You cannot cut access you never listed

One list of every user, group and role across AWS, GCP, Azure and OCI, each tagged human or machine.

Last Seen	Identity	Identifier No.	Cloud Account Name	Classification
09/28/2026 02:08:30 AM	y-openshift-in... role		aws AccuKnox-dev	machine
09/28/2026 02:08:30 AM	y-openshift-in... role		aws AccuKnox-dev	machine
09/28/2026 02:08:30 AM	y-openshift-cluster-csi-drivers... role	arn:aws:iam	aws AccuKnox-dev	machine
09/28/2026 02:08:30 AM	y-openshift-cloud-network-co... role	arn:aws:iam	aws AccuKnox-dev	machine

CIEM identity list with the cloud provider filter. help.accuknox.com/getting-started/ciem-onboarding

DO

- Onboard every cloud account with the CIEM toggle on. It is on by default in Step 2 of 3.
- Filter by Identity Type to count users, groups and roles per account.
- Review machine identities as closely as people. A CI/CD account is a machine identity.
- Give every identity a named owner before you change its access.

DON'T

- Don't inventory one cloud and assume the others match.
- Don't treat service roles as background noise. In the demo account, 637 of the identities are roles.
- Don't trust a spreadsheet of approved accounts as your inventory.

HOW ACCUKNOX CLOSSES THE GAP

CIEM reads each account's users, groups and roles under **Identities > CIEM**, and the Cloud Accounts list shows CIEM Active per account. [Onboard a cloud account for CIEM](#)

Remove the identity nobody has used

An idle identity keeps every permission it holds. Check Days Since Last Used and start with the highest value.

Age In Days	Identity Created At	Created By	Last Used	Days Since Last U...
9	09/18/2026 12:47:14 P	arn:aws:iam [redacted]	09/18/2026 12:48:03 F	9
9	09/18/2026 12:47:14 P	arn:aws:iam [redacted]	09/27/2026 11:46:46 P	0
9	09/18/2026 12:47:14 P	arn:aws:iam [redacted]	09/27/2026 11:44:18 P	0
24	09/03/2026 12:32:26 F	arn:aws:iam [redacted]	09/19/2026 09:30:21 A	8
	09/27/2026 08:37:44 A			

CIEM lifecycle columns. help.accuknox.com/getting-started/ciem-overview

DO

- Set an idle limit, such as 90 days, and flag every identity past it.
- Use Created By to find the person who can confirm an identity is still needed.
- Compare Age In Days with Last Used. An old identity used once is a removal candidate.
- Move AWS IAM users with access keys to roles with temporary credentials.

DON'T

- Don't delete a machine identity before you check what calls it.
- Don't keep a proof of concept role after the project closes.
- Don't read 0 days as safe. A value of 0 means the identity ran today, with all its policies.

HOW ACCUKNOX CLOSSES THE GAP

CIEM shows Age In Days, Created By, Last Used and Days Since Last Used for each identity, and the Raw Information tab holds the same fields as JSON. [Read the CIEM overview](#)

Fix the identities that can **escalate** first

Datadog found 2.4% of EC2 instances can reach full admin through privilege escalation. Rank identities by what their policies allow.

Identity	Resource Identifier No.	Risk Class	Cloud Account Name	Classification
 pricing-poc-AWSS3CURLam... role	arn:aws:iam:██████████	Infrastructure Modification +1	aws AccuKnox-dev	 machine
 pricing-poc-AWSCURCrawler... role	arn:aws:iam:██████████	Infrastructure Modification +1	aws AccuKnox-dev	 machine
 pricing-poc-AWSCURCrawler... role	arn:aws:iam:██████████	Data Exfiltration +1	aws AccuKnox-dev	 machine
 dspm-scanner-role role	arn:aws:iam:██████████	Credentials Exposure +2	aws AccuKnox-dev	 machine
 Opensearch_Full_Access group	arn:aws:iam:██████████	Infrastructure Modification +2	aws AccuKnox-dev	
 iam_Full_Access group	arn:aws:iam:██████████	Privilege Escalation +4	aws AccuKnox-dev	

Risk class chips in the CIEM identity list. help.accuknox.com/getting-started/ciem-overview

DO

- Work Privilege Escalation identities first, then Credentials Exposure and Data Exfiltration.
- Open the +1 or +2 chip. One identity often carries several risk classes.
- Use Total Findings by severity to order identities with the same risk class.
- Check groups as well as users. A group with Privilege Escalation passes it to every member.

DON'T

- Don't sort only by identity count. One admin group outweighs 50 idle roles.
- Don't ignore Infrastructure Modification on a machine role.
- Don't close a risk class by renaming the policy. Change its statements.

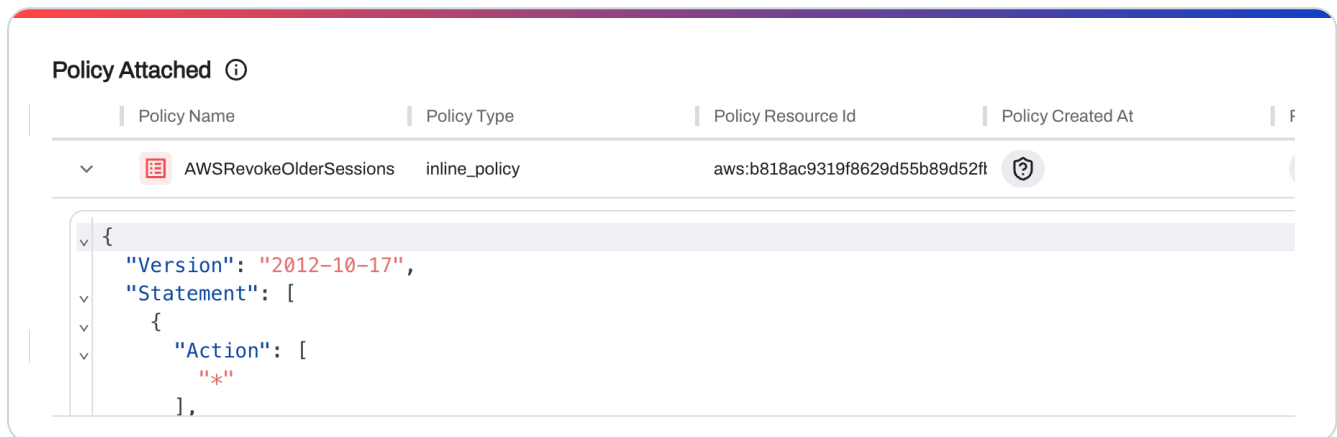
HOW ACCUKNOX CLOSES THE GAP

CIEM calculates risk classes from each identity's attached policies, such as Privilege Escalation, Data Exfiltration, Credentials Exposure and Infrastructure Modification. [See how risk classes work](#)

Source: Datadog, State of Cloud Security, October 2025, datadoghq.com.

Read the policy, not the **policy name**

A wildcard action hides behind a harmless name. Expand the policy and read every statement.



Policy Attached ⓘ

Policy Name	Policy Type	Policy Resource Id	Policy Created At
▼  AWSRevokeOlderSessions	inline_policy	aws:b818ac9319f8629d55b89d52ft	

```

{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Action": [
        "*"
      ]
    }
  ]
}

```

Policy Attached, with an inline policy expanded to JSON. help.accuknox.com/getting-started/ciem-overview

DO

- Search every statement for a wildcard in Action or Resource.
- List inline policies separately. An inline policy lives on one identity and escapes shared review.
- Prefer user managed policies your team versions over copies pasted inline.
- Recheck cloud managed policies after the provider updates them.

DON'T

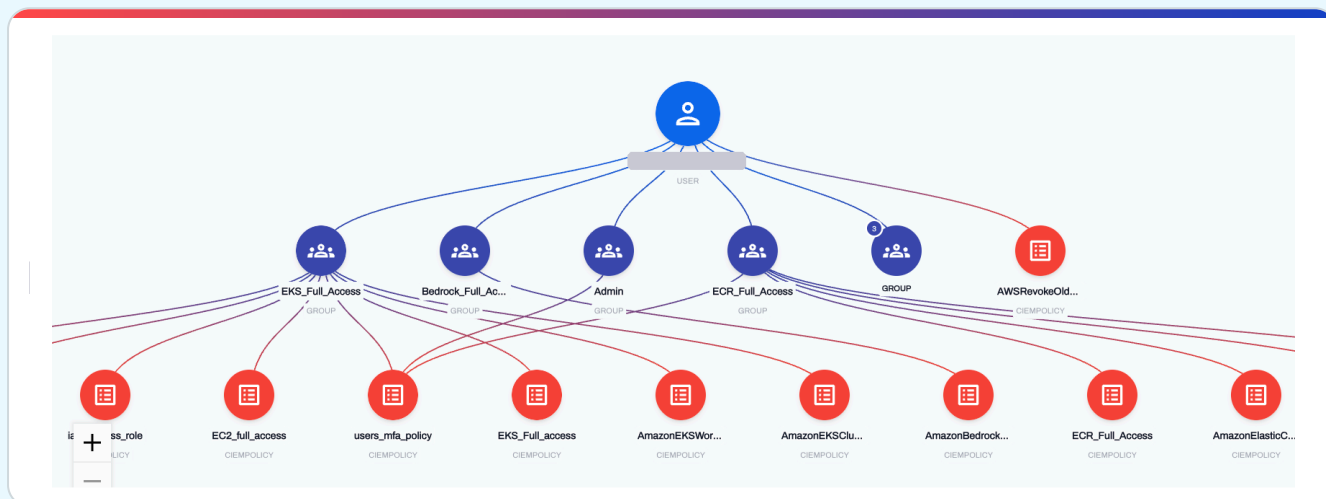
- Don't approve a policy from its name alone.
- Don't attach a FullAccess policy to fix one failed call.
- Don't leave an inline policy on a user after the user changes teams.

HOW ACCUKNOX CLOSSES THE GAP

The Overview tab lists each attached policy with its type, cloud managed, inline or user managed, and expands it to the full JSON document. [Open an identity overview](#)

Follow access through every group

The access graph draws the chain from an identity through its groups to each policy it inherits.



CIEM access graph of one demo AWS user. help.accuknox.com/getting-started/ciem-overview

DO

- Open the Access Graph for every user in an Admin group or a FullAccess group.
- Remove a user from a group when one policy in that group is the only one it needs.
- Use Related Identities to find others in the same account with the same pattern.
- Recheck the graph after each group membership change.

DON'T

- Don't review only the policies attached straight to a user.
- Don't add a person to an admin group for one task.
- Don't let groups pile up. Merge groups that grant the same policies.

HOW ACCUKNOX CLOSES THE GAP

The Access Graph reads top to bottom: the identity, its groups, and the policies each group grants. A policy attached straight to the identity sits beside the groups. [Read the access graph guide](#)

Give Kubernetes RBAC the same review

Datadog found 13% of EKS clusters run a node role with admin access, privilege escalation or broad data access.

Permission to create roles and rolebindings Critical

Age	Severity	SLA	CVE ID	Tickets Created
0 day	Critical	10 days	NA	0

[Create Ticket](#) [Ask AI](#)

Description | Solution | Other Info | Manifest | Raw Information

This permission allhugs users to define new roles and role bindings, which can lead to privilege escalation if not managed carefully. A user with this ability can potentially grant themselves or others permissions beyond their current level, bypassing existing security controls.

Finding for in resource `KIEM_Clusterrole | KIEM_Clusterrole`

First detected about 1 month ago, on 15/05/2026

Last detected about 1 month ago, on 15/05/2026

Asset Information

Asset: system:aggregate-to-admin-cluster

Asset Type: KIEM_Clusterrole

Status: Active

Ignored: No

Location

KIEM finding for a ClusterRole that can create roles and role bindings. help.accuknox.com/getting-started/3.5-release

DO

- Install the KIEM job on every cluster and schedule its scan.
- Run the query for service accounts not connected to any workload.
- List every role that can read Kubernetes secrets, and cut the ones that do not need it.
- Treat permission to create roles and role bindings as critical.

DON'T

- Don't bind cluster admin to a workload service account.
- Don't keep roles that no binding uses.
- Don't assume cloud IAM reviews cover RBAC inside the cluster.

HOW ACCUKNOX CLOSSES THE GAP

KIEM ships 15 built in queries for RBAC risk, such as excessive privileges and unused roles, and draws each entity's connections as a graph. [Set up KIEM](#)

Source: Datadog, State of Cloud Security, October 2025, datadoghq.com.

Find your gap, then take the first step

Read each row. Where the gap is true for you, take the first step this week.

IF THIS IS TRUE	ACCUKNOX CAPABILITY	FIRST STEP
Nobody can list every user, group and role in each cloud	CIEM identity list	Onboard each account with the CIEM toggle on
Roles and keys from finished projects still exist	CIEM lifecycle columns	Review the identities with the highest Days Since Last Used
You cannot say which identities can escalate privileges	CIEM risk classes	Filter to Privilege Escalation and assign owners
Policies get approved by name	CIEM policy view	Expand inline policies and search for wildcards
Group membership grants access nobody reviewed	CIEM access graph	Open the graph for every Admin group member
Kubernetes service accounts never get reviewed	KIEM	Install the KIEM job and run the unused role query

See who can touch your cloud

Book a demo and walk through CIEM and KIEM on your own gap check, from the identity list to the access graph.

[Book a demo](#)[Open the CIEM docs](#)

2026

KuppingerCole CNAPP Leadership Compass features AccuKnox Zero Trust CNAPP.

2

Best Practices recognitions in 2026, one global and one regional.

4

clouds in one CIEM identity list: AWS, GCP, Azure and OCI.

15

built in KIEM queries for Kubernetes RBAC risk.

Sources: accuknox.com/analyst-recognition, help.accuknox.com/getting-started/ciem-overview, help.accuknox.com/use-cases/kiem. CIEM is in beta.